

Privacy Guard

Extensão Firefox para detecção e bloqueio de rastreadores

Relatório de validação: DuckDuckGo Privacy Test Pages, análise de 3 sites reais e pontuação de privacidade

Carolina Eskenazi

Cibersegurança — Avaliação Intermediária — Prof. João Eduardo Luisi

Inspiração — setembro de 2026

Repositório: https://github.com/carolinaeskenazi/cyberseg_intermediaria

1. Ambiente e escopo

Este relatório reúne os entregáveis 2, 3 e 4 da avaliação. O plugin (entregável 1) está no repositório, na pasta *privacy-guard/*, com instruções de instalação via *about:debugging* no README. Todas as evidências citadas (prints e arquivos HAR) estão em *privacy-guard/evidencias/*.

Ambiente de teste. Firefox em Kali Linux (VM), Enhanced Tracking Protection no modo padrão, extensão carregada como temporária. Os HARs foram exportados pela aba Network do DevTools logo após o carregamento de cada site. O Blacklight (The Markup) foi executado pela interface web, que usa um navegador headless próprio. O uBlock Origin foi instalado com as listas padrão e ativado apenas na etapa de comparação.

O que o plugin mede. Resumo das técnicas (detalhes no README):

Detecção	Como é feita
Terceira parte	webRequest.onBeforeRequest; hostname da requisição diferente e não subdomínio do hostname do documento principal.
Cookies	cookies.getAll() para a URL da página e para cada domínio terceiro; classifica 1ª/3ª parte pelo domínio do cookie e sessão/persistente pelo atributo session.
Storage HTML5	Content script em todos os frames lê localStorage, sessionStorage e indexedDB.databases(); reporta por contexto (frame/origem).
Canvas	Script injetado na página sobrescreve toDataURL, toBlob e getImageData e registra cada chamada com horário e stack.
Cookie sync (indicador)	Mesmo valor de identificador (parâmetro de URL) aparecendo em requisições para domínios diferentes. É um <i>indicador</i> de sincronização de identificadores: sozinho, não prova que houve troca de cookies entre empresas diferentes.
Bounce tracking	Padrão de navegação A -> B -> A em até 30 s, redirect HTTP entre domínios no main_frame e parâmetros bounceUid*.
Hijacking/hook	Construtor WebSocket interceptado; WebSocket para domínio terceiro é indicador.
Blocklist	Domínios do usuário cancelados em onBeforeRequest (incluindo subdomínios).

Sobre "terceira parte". Neste trabalho, terceira parte é uma classificação heurística baseada em *hostname*: não representa necessariamente uma entidade organizacional diferente. CDNs e APIs do próprio grupo (ex.: glbimg.com para a Globo, mlstatic.com para o Mercado Livre) contam como terceiros. Assim, "75 terceiros" significa 75 hostnames externos, não 75 empresas. Da mesma forma, os indicadores de canvas, cookie sync, bounce e hook registram *comportamentos compatíveis* com essas técnicas (por isso o popup mostra "Possível"), e não uma confirmação.

2. Execução nas DuckDuckGo Privacy Test Pages

A tabela resume cada teste: o resultado esperado (o que a própria página reporta ou provoca), o que o plugin mostrou e a explicação técnica de cada divergência. Os prints de cada linha estão nas subseções 2.1 a 2.7.

Teste	Esperado (página)	Resultado do plugin	Divergência e explicação
Tracker Reporting — 1 major via img	1 rastreador (facebook.com) carregado via .	1 domínio terceiro: facebook.com (1 req). Score 95 (-5).	Nenhuma no domínio. O plugin não usa lista de rastreadores (ex.: Tracker Radar), então reporta "terceira parte", não "rastreador major".
Tracker Reporting — 1 major via script	1 rastreador (doubleclick.net) via <script>.	1 domínio terceiro: doubleclick.net (1 req).	Nenhuma. Mesma observação sobre classificação.
Tracker Reporting — via fetch	Rastreador carregado via fetch() ("Tracker loaded").	1 domínio terceiro: facebook.com (1 req).	Nenhuma: o webRequest vê fetch/XHR da mesma forma que img/script.
Tracker Blocking (request-blocking), sem blocklist	Sem proteção, as ~20 requisições para bad.third-party.site carregam (verde).	bad.third-party.site com 21 requisições; 1 cookie de 3ª parte persistente.	Nenhuma: o plugin só bloqueia o que está na lista do usuário.
Tracker Blocking, com bad.third-party.site na blocklist	Todas as requisições para o domínio falham (vermelho).	Todas falham, exceto serviceworker-fetch (verde). Hook: WebSocket para bad.third-party.site (TERCEIRO).	Requisições feitas por um Service Worker chegam ao webRequest com <i>tabId</i> = -1, porque não pertencem a uma aba. O background descarta <i>tabId</i> < 0 (background.js:440) antes de consultar a blocklist, então essa requisição passa.
Storage Blocking	Página grava um número (43) em 23 mecanismos, em 1ª parte e em iframes de terceiros (safe/tracking); 1 falha (WebSQL).	3 domínios terceiros; storage por contexto: TOP e iframes good.third-party.site, broken.third-party.site e convert.ad-company.site com 1 item cada. Cookies: 7 de 1ª parte, 0 de 3ª parte .	A página reporta "tracking third party header cookie - OK" dentro dos iframes, mas o plugin mostra 0 cookies de 3ª parte. O Firefox (Total Cookie Protection) grava cookies de iframes de terceiros em um pote particionado pelo site de topo, e cookies.getAll() sem <i>partitionKey</i> só devolve cookies não particionados. A falha única é WebSQL: "openDatabase is not defined" (não existe no Firefox).
Storage Partitioning	Em www.first-party.site: dados recuperados em 21 mecanismos, todos "pass" (particionados).	1 domínio terceiro (privacy-test-pages.site, 3 req). Contextos: TOP www.first-party.site (0 itens) e 2 iframes www.first-party.site (1 item cada).	O plugin mostra o storage de cada contexto, mas identifica o contexto só pelo hostname, sem a chave de partição (site de topo). Por isso os iframes aparecem como "www.first-party.site" e não é possível ver <i>que</i> estão particionados, só que existem. O resumo "Storage HTML5: Detectado, 1 item" veio de um iframe, e não do TOP (0 itens): o popup usa tabs.sendMessage sem <i>frameId</i> e o primeiro frame a responder vence.
Fingerprinting (canvas)	A página chama várias APIs de fingerprint e mostra os valores (canvas-2d-todataurl, audio-*, etc.).	Canvas: Possível . toDataURL 4, getImageData 1, 5 eventos com horário (14:14:02.382 a .706).	Detecta o canvas. Os vetores de áudio (AnalyserNode, copyFromChannel), WebGL e propriedades do navegador que a página também testa não são interceptados pelo plugin.
Bounce Tracking	bad.third-party.site recebe o usuário e o repassa ao destino, passando o ID "55" via localStorage e cookie.	Bounce: Possível . 3 eventos "bad.third-party.site -> X -> bad.third-party.site" e UID via localStorage/cookie = 55. Redirecionamentos HTTP: 0.	Detecta a técnica e o identificador. O salto é feito por navegação JavaScript, não por HTTP 3xx, então onBeforeRedirect não registra nada (0 redirects). Como cada link foi testado em sequência, bad.third-party.site aparece várias vezes no histórico e a heurística A -> B -> A reporta as triplas centradas nele, e não na ordem canônica publisher -> bad -> destino.
Query Parameters	Landing page recebe "fbclid=12345&fb_source=something&u=14"; um navegador protegido removeria fbclid.	1 parâmetro suspeito: fbclid=12345. Cookie sync: não detectado.	O plugin detecta, mas não remove parâmetros (não reescreve URLs). fb_source e u não foram marcados: não estão na lista de nomes conhecidos e os valores têm menos de 16 caracteres. Não há cookie sync porque o valor só aparece em um domínio.

2.1 Tracker Reporting

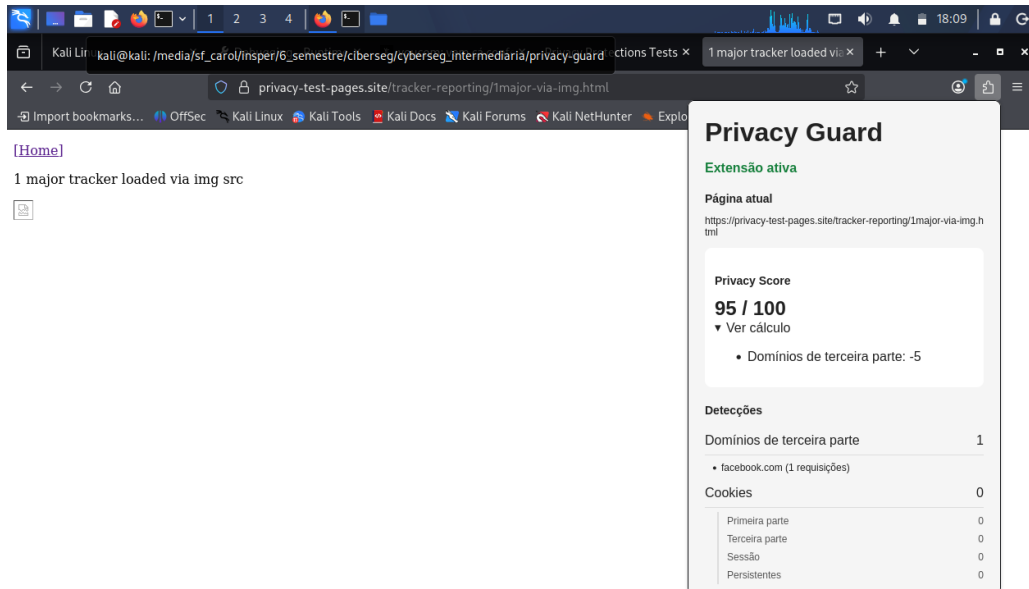


Figura 1 — 1 major tracker via img: facebook.com detectado como terceira parte. (evidencias/ddg/tracker-reporting-img.png)

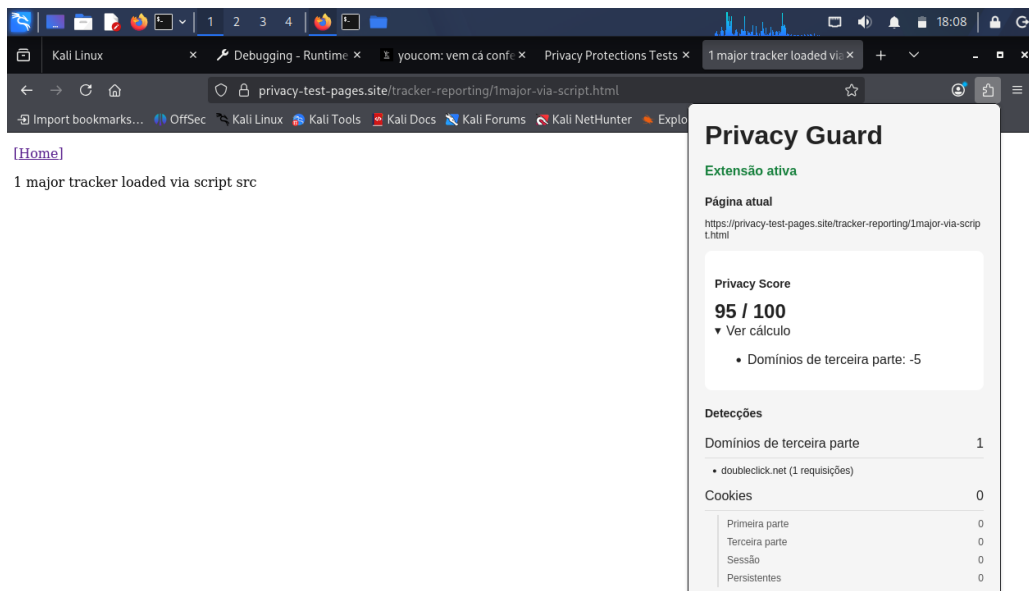


Figura 2 — 1 major tracker via script: doubleclick.net. (evidencias/ddg/tracker-reporting-script.png)

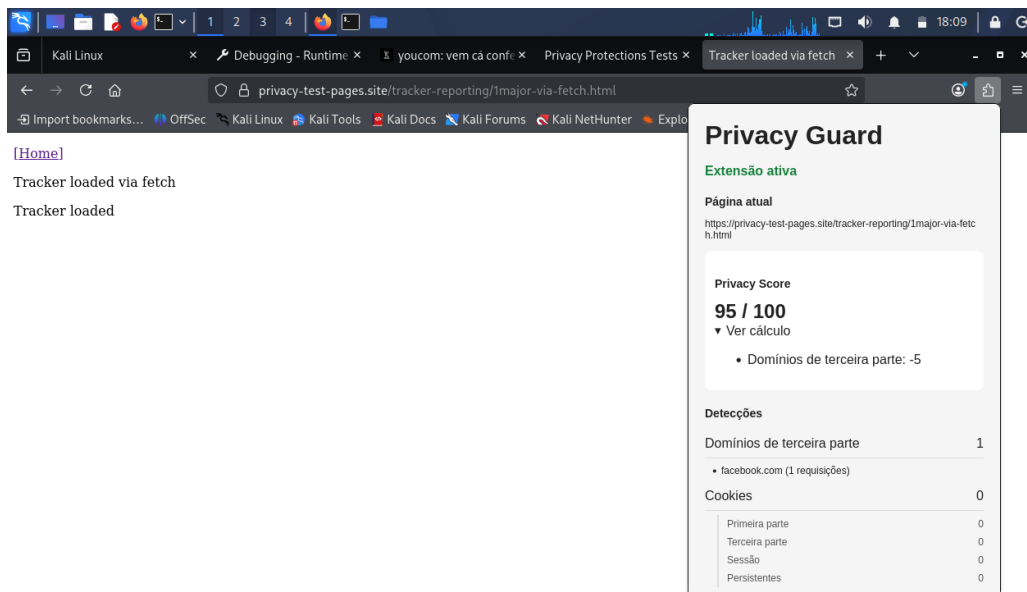


Figura 3 — Tracker via fetch: facebook.com. (evidencias/ddg/tracker-reporting-fetch.png)

2.2 Tracker Blocking

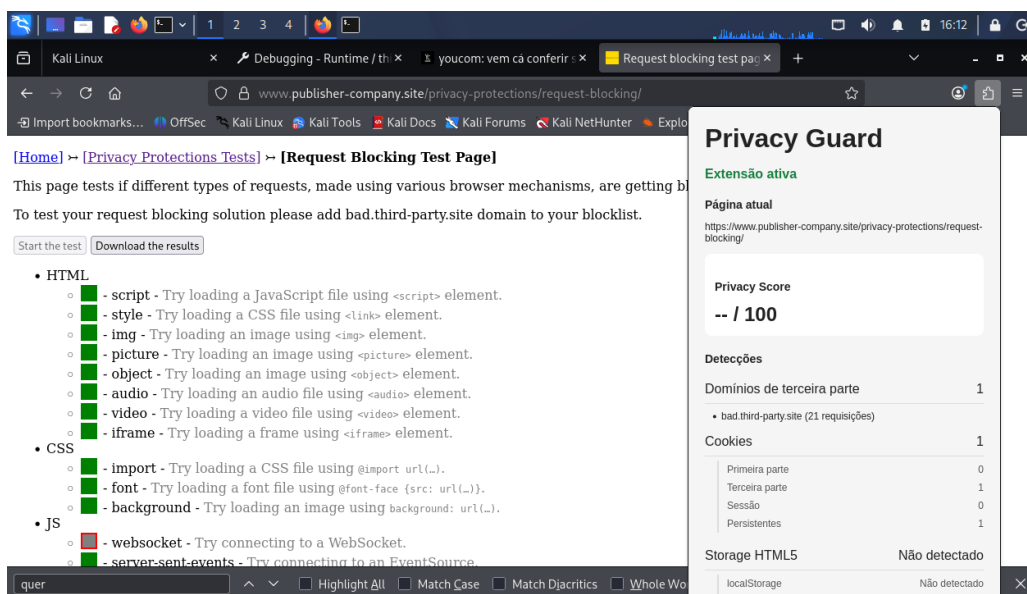


Figura 4 — Request blocking sem blocklist: 21 requisições para bad.third-party.site, todas carregadas. (evidencias/ddg/tracker-block.png)

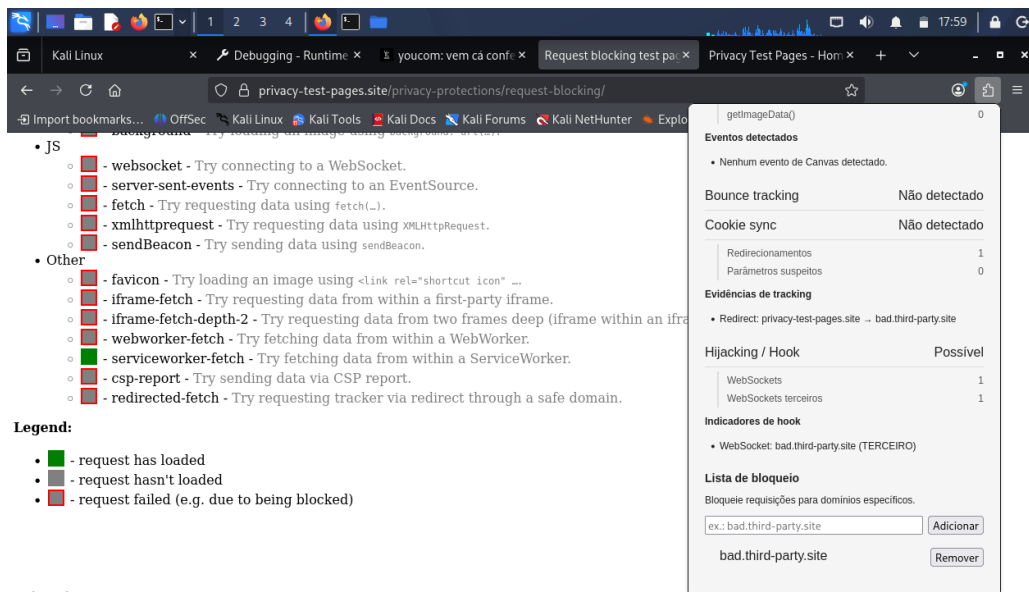


Figura 5 — Com bad.third-party.site na blocklist: requisições falham, exceto serviceworker-fetch; WebSocket terceiro sinalizado como hook. (evidencias/ddg/tracker-blocking-blocklist.png)

2.3 Storage Blocking

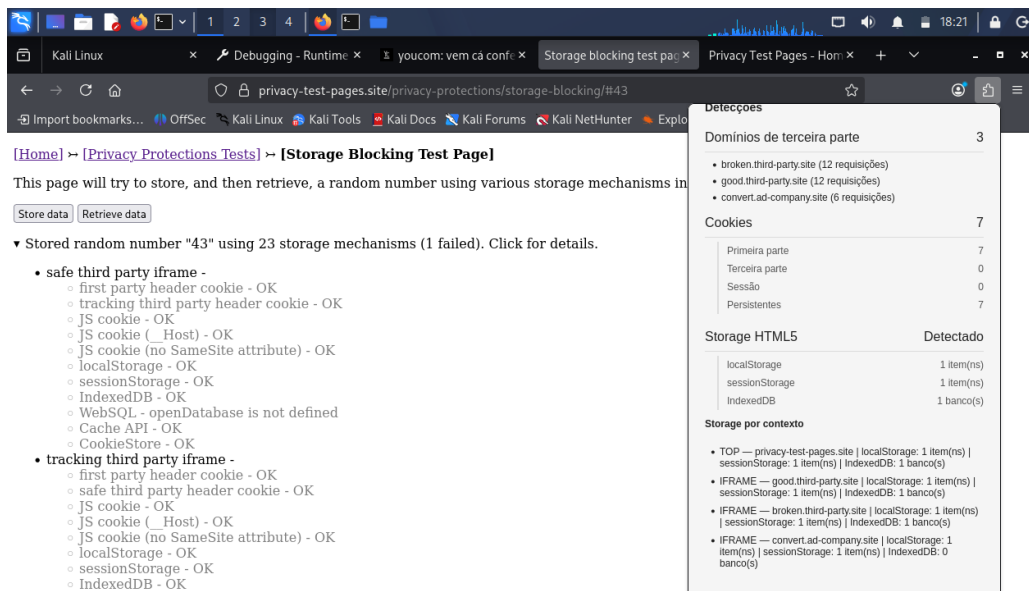


Figura 6 — Storage por contexto (TOP e 3 iframes de terceiros); 0 cookies de 3ª parte visíveis. (evidencias/ddg/storage-blocking.png)

2.4 Storage Partitioning

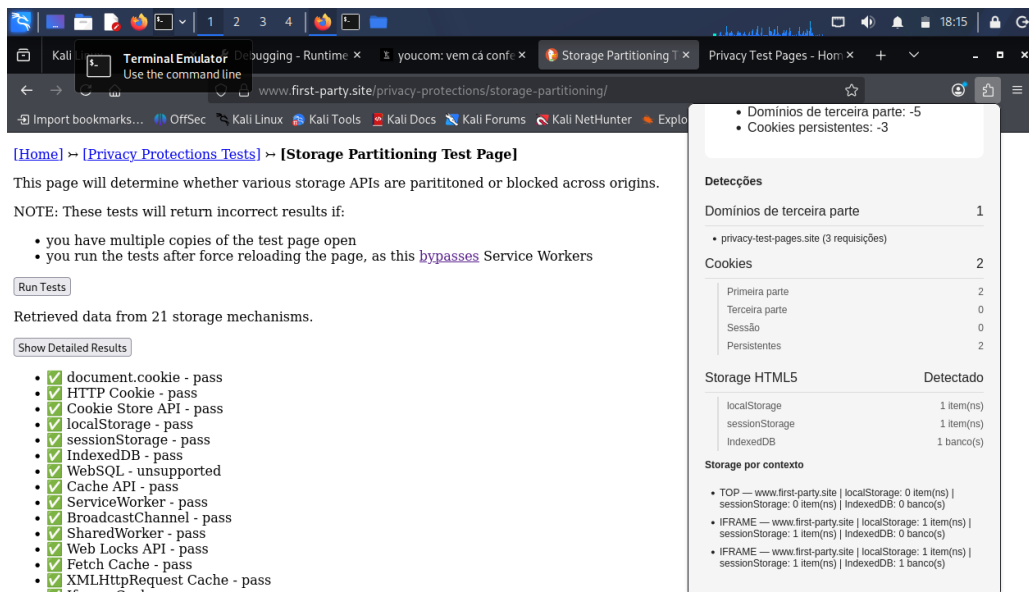


Figura 7 — 21 mecanismos "pass"; plugin mostra os contextos www.first-party.site. (evidencias/ddg/storage-partitioning.png)

2.5 Fingerprinting / canvas

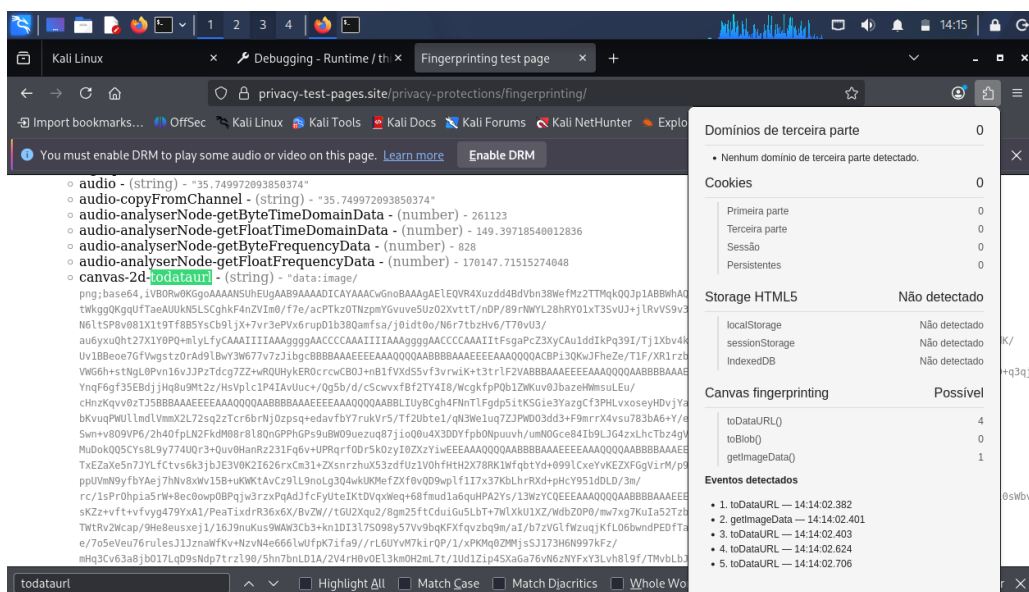


Figura 8 — Canvas: 4 toDataURL + 1 getImageData com horário de cada evento. (evidencias/ddg/canvas-fingerprinting.png)

2.6 Bounce Tracking

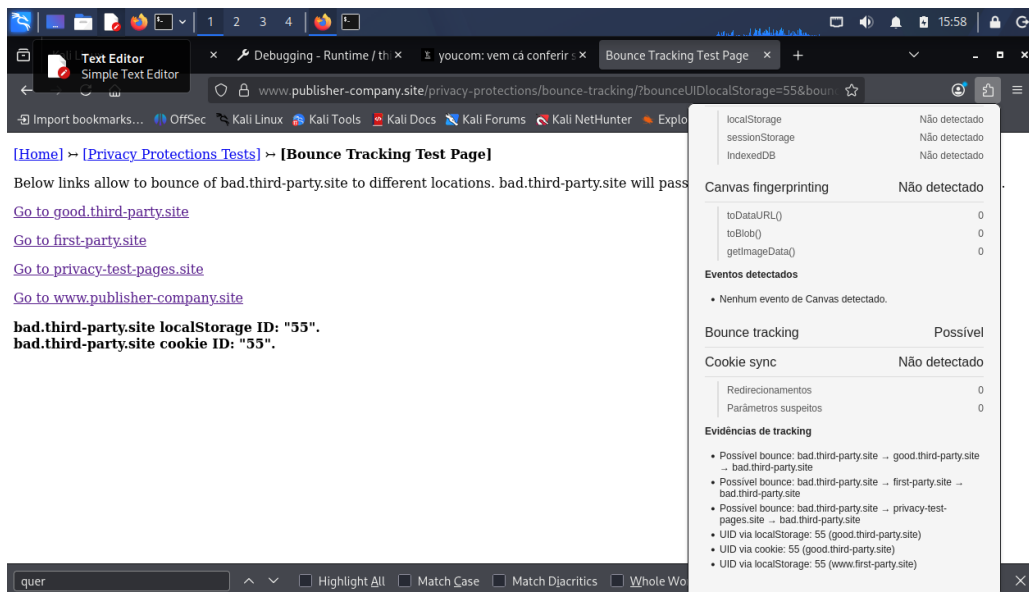


Figura 9 — Bounce possível e UID 55 via localStorage/cookie. (evidencias/ddg/bounce-tracking.png)

2.7 Query Parameters

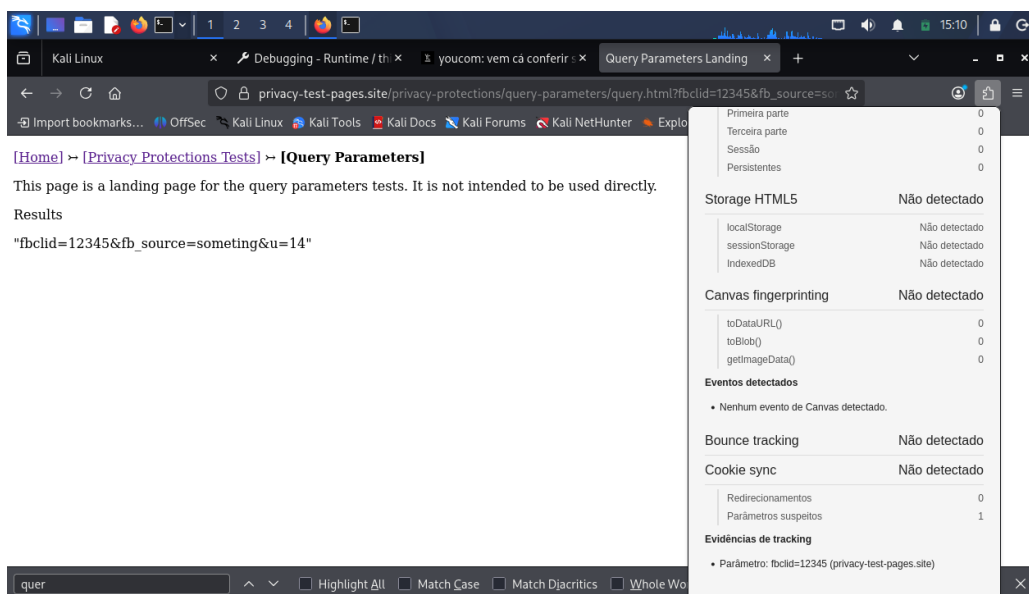


Figura 10 — Parâmetro fbclid=12345 sinalizado. (evidencias/ddg/query-parameter.png)

3. Análise de 3 sites reais

Sites analisados: **youcom.com.br** (site-1), **globo.com** (site-2) e **mercadolivre.com.br** (site-3). Para cada site há o HAR (*evidencias/har/*), os prints do plugin, do Blacklight e do uBlock Origin (*evidencias/sites/site-N/*). Os números do HAR abaixo foram extraídos dos próprios arquivos (hosts de terceiros, cabeçalhos Set-Cookie de respostas de terceiros e redirects).

Diferenças de método que explicam boa parte das divergências:

- **Unidade de contagem.** O plugin conta *hostnames* terceiros (ex.: *us.creativecdn.com* e *cm.creativecdn.com* são 2). O uBlock conta domínios registráveis (eTLD+1) e o Blacklight conta *rastreadores de anúncio* de uma lista, não domínios.
- **Ambiente diferente.** O Blacklight visita o site uma vez, em um Chromium headless (perfil mobile, EUA), sem particionamento de cookies e sem bloqueio. A nossa sessão foi em Firefox com Enhanced Tracking Protection e Total Cookie Protection, no Brasil, com interação (scroll).
- **Cookies particionados.** Cookies gravados por terceiros ficam particionados no Firefox e não são retornados por *cookies.getAll()* sem *partitionKey*. Além disso, a consulta é feita com o hostname exato (ex.: *print1.mercadoclics.com*), e cookies com domínio pai (*.mercadoclics.com*) não entram.
- **Janela de tempo.** O popup acumula tudo desde o carregamento até o momento do print (alguns minutos, incluindo leilões de anúncios), enquanto o HAR foi exportado em um momento específico.

3.1 youcom.com.br (site-1)

Métrica	Plugin	HAR	Blacklight	uBlock Origin
Terceiros	43 hostnames	58 hostnames / 44 domínios registráveis	13 ad trackers	10 de 15 domínios conectados bloqueados
Cookies de 3ª parte	6 (de 62; 56 de 1ª)	30 Set-Cookie de terceiros (tiktok _ttp, criteo uid, bing MUID, clarity CLID, facebook fr, creativecdn...)	9	-
Sessão / persistentes	14 / 48	-	-	-
Storage HTML5	TOP: localStorage 25, IndexedDB 1; iframe google.com: 1	-	-	-
Canvas	Não detectado	-	Não encontrado ("evades cookie blockers")	-
Cookie sync	Possível (stats.g.doubleclick.net <-> google.com.br etc.)	c.bing.com/c.gif?...CtsSyncId=...	-	-
Bounce	Não detectado	sem 3xx de main_frame entre domínios	-	-
Hook (WebSocket)	0	0 URLs ws(s)://	-	-
Pixels	facebook.net/, com, analytics.tiktok.com, bat.bing.com, c.clarity.ms, ct.pinterest.com na lista	facebook.com/tr (beacon), analytics.tiktok.com, clarity.ms, pinterest	Facebook: não; TikTok: sim; Google Analytics: sim; X: não; session recording: não	-
Score	32 / 100	-	sem score numérico	-

Reconciliação.

- **Facebook: plugin detecta, Blacklight não.** O HAR tem *connect.facebook.net/en_US/fbevents.js* e um POST para *www.facebook.com/tr/* (iniciado por *fbevents.js:292*, tipo beacon), além de Set-Cookie *fr* de facebook.com. O pixel é carregado pelo Google Tag Manager (GTM-579D86) e disparado com a

interação do usuário; a visita headless do Blacklight, sem scroll e com perfil dos EUA, não chegou a disparar esse evento.

- **Session recording: plugin vê o domínio, Blacklight diz que não há.** O HAR tem `www.clarity.ms/tag/jjt8vnjiin` (Microsoft Clarity, gravação de sessão) e Set-Cookie CLID/SM de `clarity.ms`. O Blacklight procura a gravação ativa (eventos enviados); o plugin não classifica o tipo de serviço, só lista `c.clarity.ms` como terceiro.
- **TikTok e Google Analytics: concordam.** `analytics.tiktok.com` (10 requisições no popup) e `stats.g.doubleclick.net/g/collect` com `tid=G-2S7ZD0E444` aparecem no plugin e no HAR.
- **Contagem de terceiros (43 x 13 x 10).** O plugin conta hostnames; a lista inclui CDNs e fontes (`fonts.gstatic.com`, `resources.digital-cloud-west.medallia.com`), que não são ad trackers para o Blacklight. O uBlock só conta 15 domínios porque, ao bloquear os 10 scripts iniciais (GTM, pixels), os leilões de anúncios (`rubiconproject`, `pubmatic`, `adnxs`, `criteo`...) que aparecem no HAR nunca chegam a ser disparados.
- **Cookies de 3ª parte (6 x 9 x 30).** O HAR tem 30 Set-Cookie de terceiros, mas a maioria é gravada em contexto de terceiro e fica particionada (TCP), ficando invisível para `cookies.getAll()` sem `partitionKey`. O Blacklight, sem particionamento, vê 9.
- **Indicador de cookie sync: só o plugin reporta.** O mesmo identificador aparece em `stats.g.doubleclick.net` e em `www.google.com.br / googleads.g.doubleclick.net`, e o HAR mostra `c.bing.com/c.gif?...CtsSynclD=3316BB...`, um endpoint de sincronização da Microsoft (o nome do parâmetro indica sync, mas o HAR não mostra o parceiro que recebe o ID). Doubleclick e `google.com.br` são do mesmo grupo (Alphabet), então, desse par, é propagação de identificador e não prova de troca entre empresas. O Blacklight não tem teste de cookie sync.

The screenshot shows a web browser window with the URL `www.youcom.com.br/?gad_source=1&gad_campaignid=310081699&gclid=EAlaQobChMlytiGlc...`. The page displays the Youcom logo and a privacy score overlay. The score is 32 / 100, with a breakdown: Domínios de terceira parte: -20, Cookies de terceira parte: -15, Cookies persistentes: -10, Storage HTML5: -8, and Cookie sync: -15. Below the score, a list of third-party domains is shown, including `us.creativecdn.com`, `analytics.tiktok.com`, `googletagmanager.com`, `google.com`, `gstatic.com`, `google.com.br`, `bat.bing.com`, `resources.digital-cloud-west.medallia.com`, and `googleads.g.doubleclick.net`. The network inspector at the bottom shows a list of requests, including `events` from `analytics-fe.digita...` and `act` from `analytics.tiktok.com`.

Figura 11 — youcom: score 32 e lista de terceiros. (evidencias/sites/site-1/score-privacy.png)

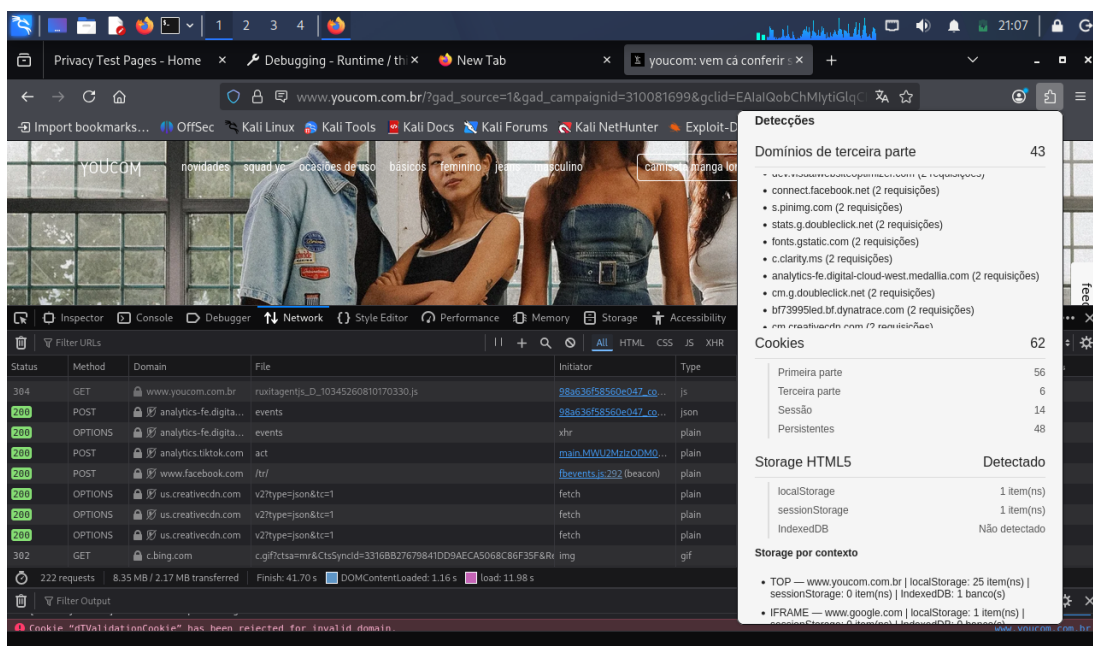


Figura 12 — youcom: 62 cookies (56/6; 14 sessão/48 persistentes) e storage por contexto. (evidencias/sites/site-1/cookies.png)

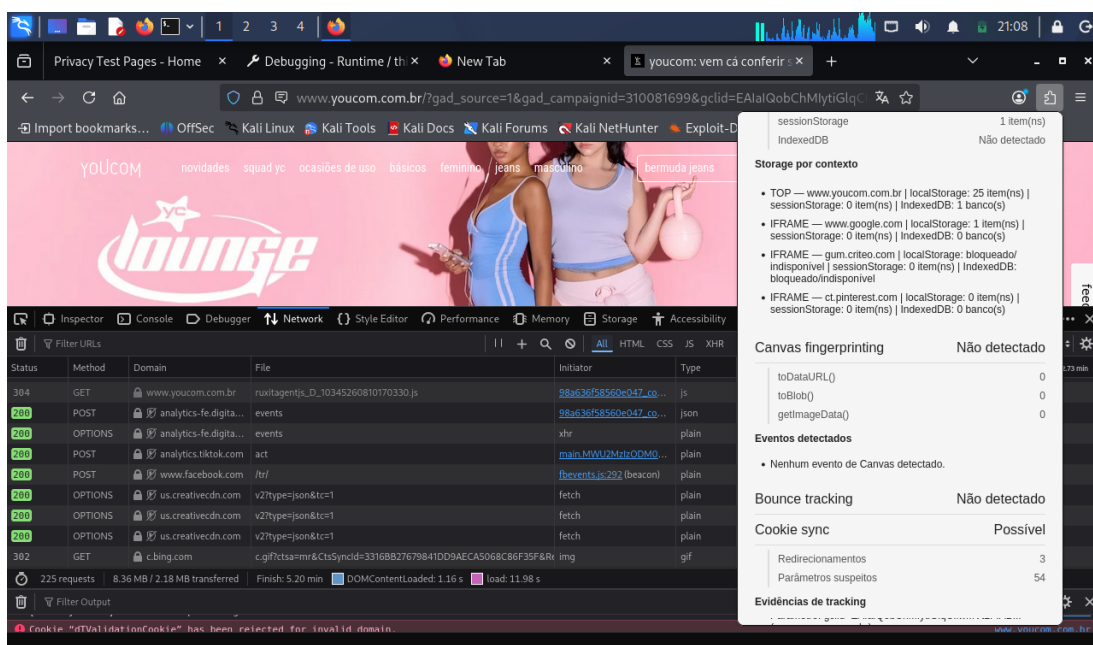


Figura 13 — youcom: storage por contexto, canvas e bounce não detectados. (evidencias/sites/site-1/bounce-tracking.png)

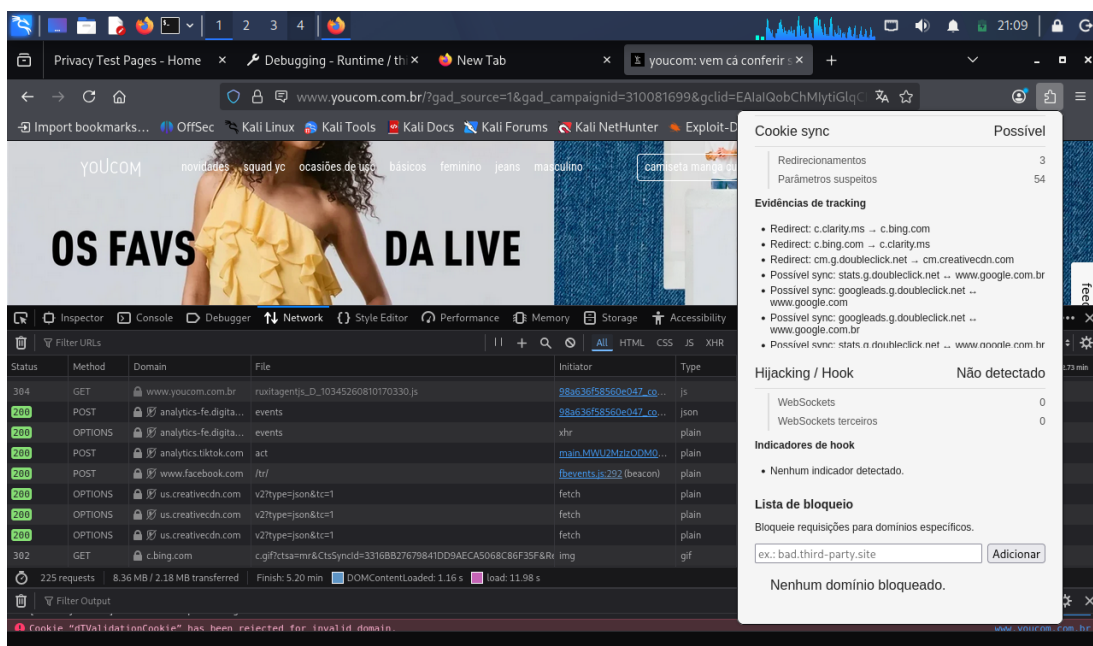


Figura 14 — youcom: cookie sync possível, 3 redirects, 54 parâmetros suspeitos; nenhum hook. (evidencias/sites/site-1/cookie-sync.png)

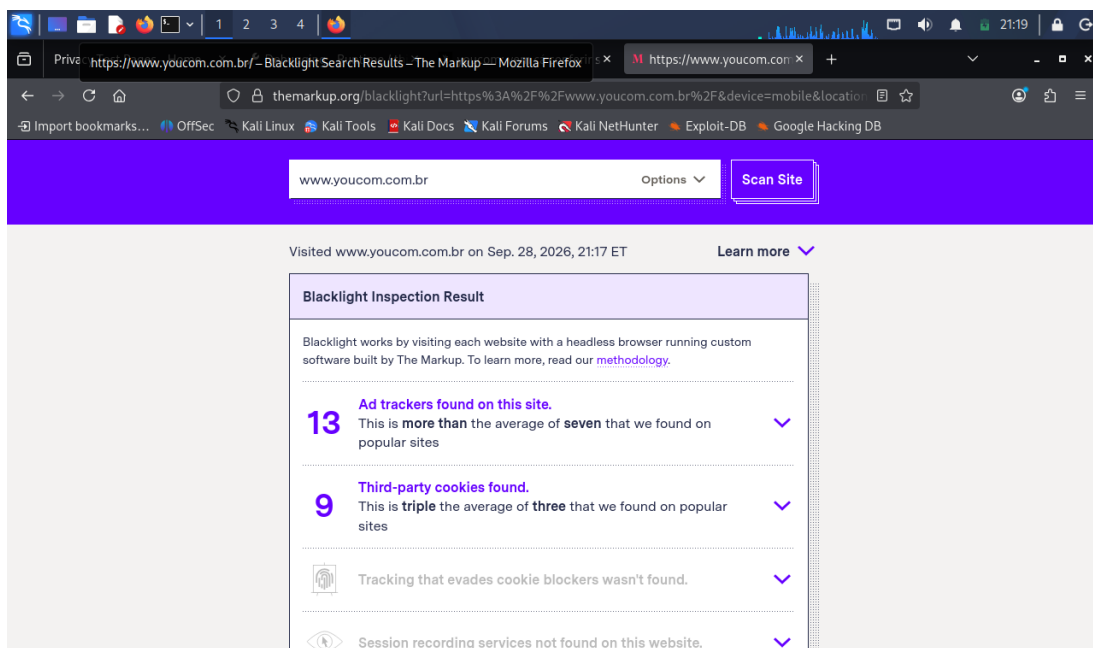


Figura 15 — Blacklight youcom: 13 ad trackers, 9 cookies de terceiros. (evidencias/sites/site-1/youcom-blacklight.png)

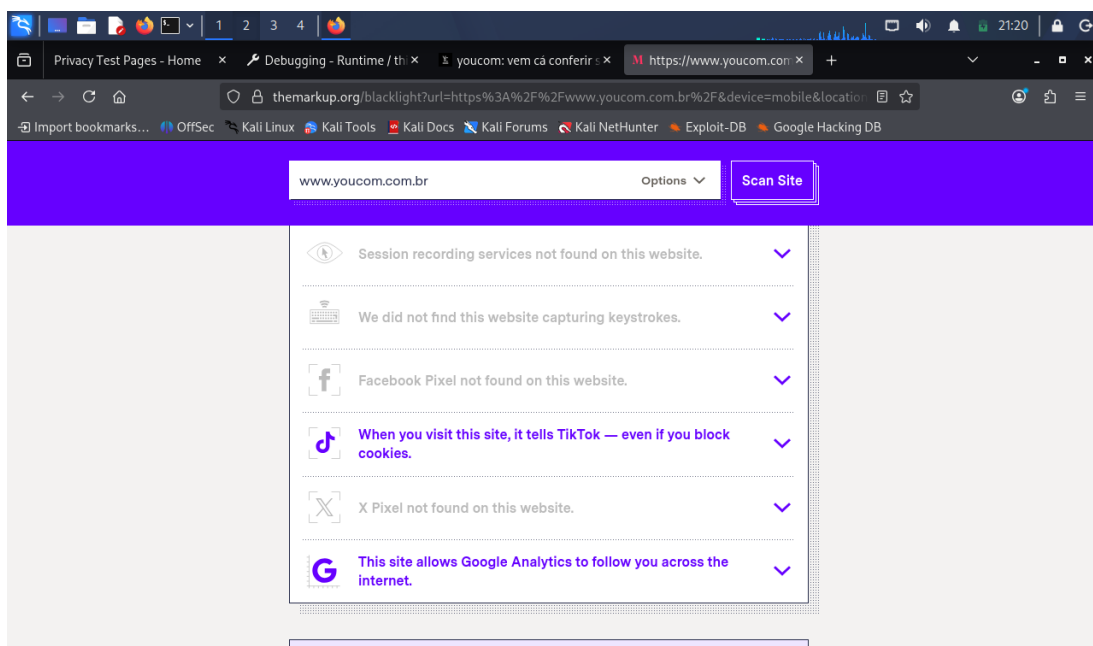


Figura 16 — Blacklight youcom: TikTok e Google Analytics; Facebook Pixel não encontrado.
(evidencias/sites/site-1/youcom-blacklight-2.png)

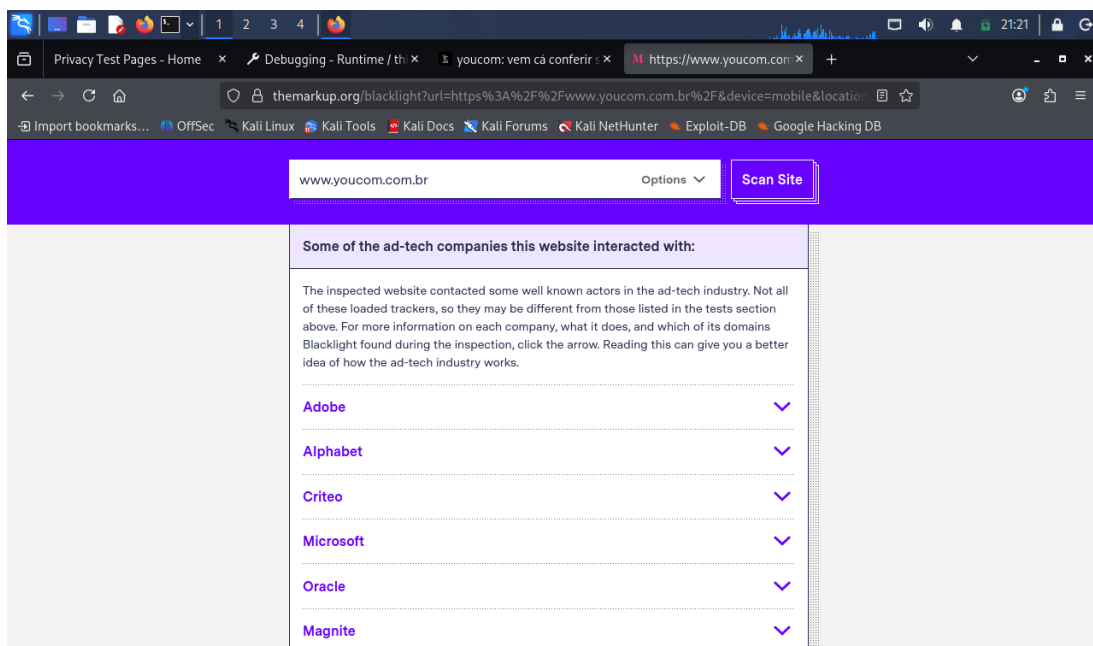


Figura 17 — Blacklight youcom: empresas de ad-tech (Adobe, Alphabet, Criteo, Microsoft, Oracle, Magnite...).

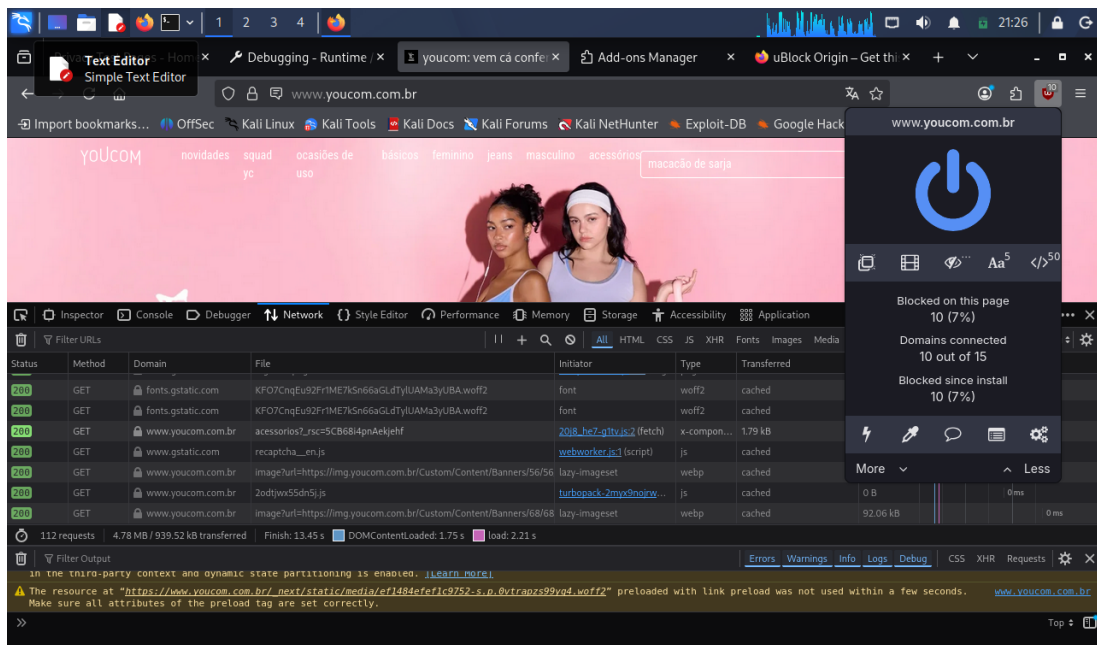


Figura 18 — uBlock youcom: 10 bloqueios (7%), 10 de 15 domínios. (evidencias/sites/site-1/ublock-youcom.png)

3.2 globo.com (site-2)

Métrica	Plugin	HAR	Blacklight	uBlock Origin
Terceiros	75 hostnames	42 hostnames / 26 domínios registráveis (238 entradas)	28 ad trackers	47 bloqueios (20%); 10 de 23 domínios
Cookies de 3ª parte	7 (de 48; 41 de 1ª)	7 Set-Cookie de terceiros: doubleclick test_cookie, scorecardresearch UID, facebook fr, criteo uid	34	-
Sessão / persistentes	1 / 47	-	-	-
Storage HTML5	TOP: localStorage 27, sessionStorage 8, IndexedDB 2; iframes criteo/pubmatic/safeframe bloqueados	-	-	-
Canvas	Não detectado	-	Não encontrado	-
Cookie sync	Possível (127 parâmetros suspeitos)	gum.criteo.com/sid/json, rp.liadm.com (LiveRamp) com duid	-	-
Bounce	Possível	nenhum 3xx de main_frame entre domínios	-	-
Hook (WebSocket)	0	0	-	-
Pixels	facebook, googletagmanager, doubleclick na lista	fbevents.js, facebook.com/tr, gtag AW-319734835	Facebook: sim; GA: sim; TikTok/X: não	-
Score	20 / 100	-	sem score numérico	-

Reconciliação.

- **Facebook, Google Analytics e ausência de TikTok/X: concordam.** O HAR tem connect.facebook.net/en_US/fbevents.js, POST www.facebook.com/tr/ e stats.g.doubleclick.net/g/collect (tid=G-5401XJ0K8J), e não tem nenhuma requisição para tiktok ou twitter.
- **Terceiros (75 x 42 no HAR).** O popup foi aberto ~1,7 min depois do carregamento (391 requisições no DevTools) e acumula as requisições dos leilões de anúncios (ib.adnxs.com, securepubads.g.doubleclick.net, fastlane.rubiconproject.com...), enquanto o HAR exportado tem 238 entradas. Além disso, domínios do próprio grupo (s3.glbimg.com com 57 requisições, s2-home-globo.glbimg.com, mab.g.globo) contam como terceira parte no plugin porque o domínio registrável é diferente de globo.com. O Blacklight conta 28 porque só considera domínios que estão na lista de ad trackers.
- **Cookies de 3ª parte (7 x 34).** O plugin coincide exatamente com o HAR: há 7 Set-Cookie de terceiros nas respostas. A diferença para o Blacklight é de ambiente: o Firefox com ETP bloqueia cookies de rastreadores conhecidos (Disconnect list), o que é visível pelos ícones de escudo nas linhas de tpssc-ue1.doubleclickverify, api.permutive.com e rp.liadm.com no DevTools. O headless do Blacklight aceita todos e roda a cadeia completa de cookie sync do prebid.
- **Bounce: falso positivo do plugin.** O HAR não tem nenhum redirect 3xx de main_frame entre domínios. Os 5 redirects são de sub-recursos (ads-library.globo.com, scorecardresearch beacon.js) e o goidc.globo.com/auth -> www.globo.com/login-callback (login silencioso, error=login_required) é de iframe (Sec-Fetch-Dest: iframe no HAR). A marcação veio do histórico de navegação da aba ("Redirect: google.com -> globo.com" no popup, ou seja, a chegada ao site por um resultado de busca), que a heurística A -> B -> A / redirect de main_frame trata como bounce. Os redirects para "49ccbfd8-..." são para um recurso local de extensão (moz-extension://UUID): scripts de doubleclick substituídos por um shim (SmartBlock do Firefox), não um domínio real.

- **Indicador de cookie sync: só o plugin reporta.** O HAR tem gum.criteo.com/sid/json?origin=prebid e rp.liadm.com/p?...duid=da5812f14a1e--01m3nd3bw... (LiveRamp), endpoints conhecidos de sincronização de identificadores entre SSPs; aqui o indicador é compatível com cookie sync real entre empresas diferentes. O Blacklight lista Criteo, Lotame, OpenX, PubMatic e Magnite como empresas contatadas, mas não tem teste específico de sync.
- **uBlock (47 bloqueios, 20%).** Os bloqueios visíveis incluem data.pendo.io e horizon-track.globo.com / horizon.globo.com (telemetria da própria Globo). O plugin marca horizon.globo.com como primeira parte (subdomínio de globo.com), então não o conta como terceiro, embora a lista do uBlock o considere rastreador.

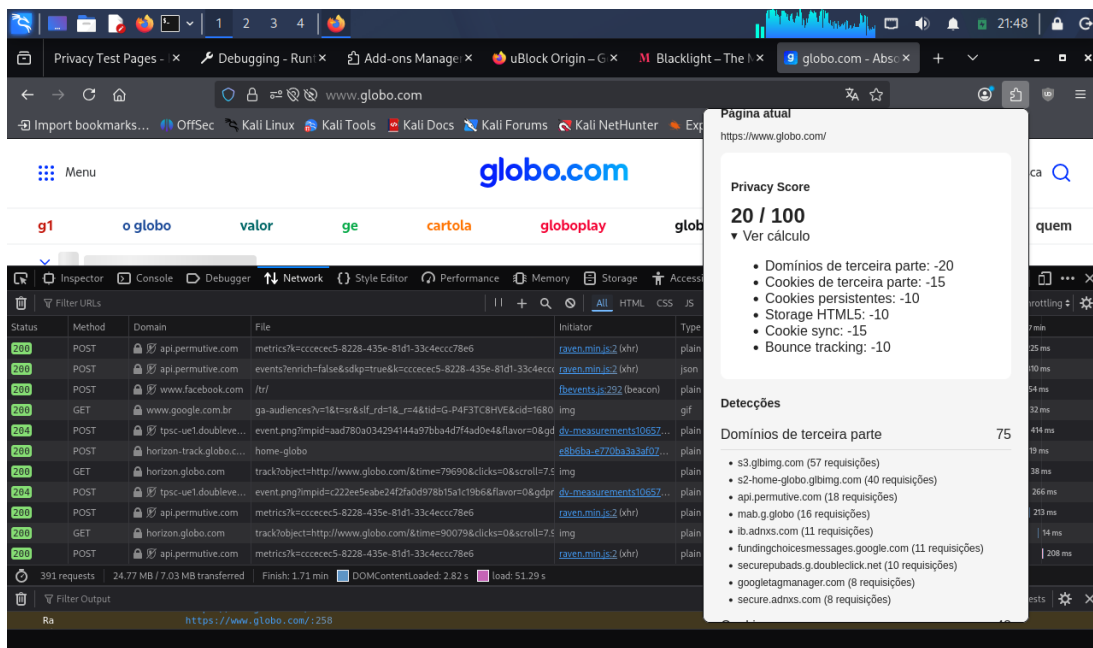


Figura 19 — globo: score 20 e 75 domínios de terceira parte. (evidencias/sites/site-2/privacy-score-domínios-3-parte.png)

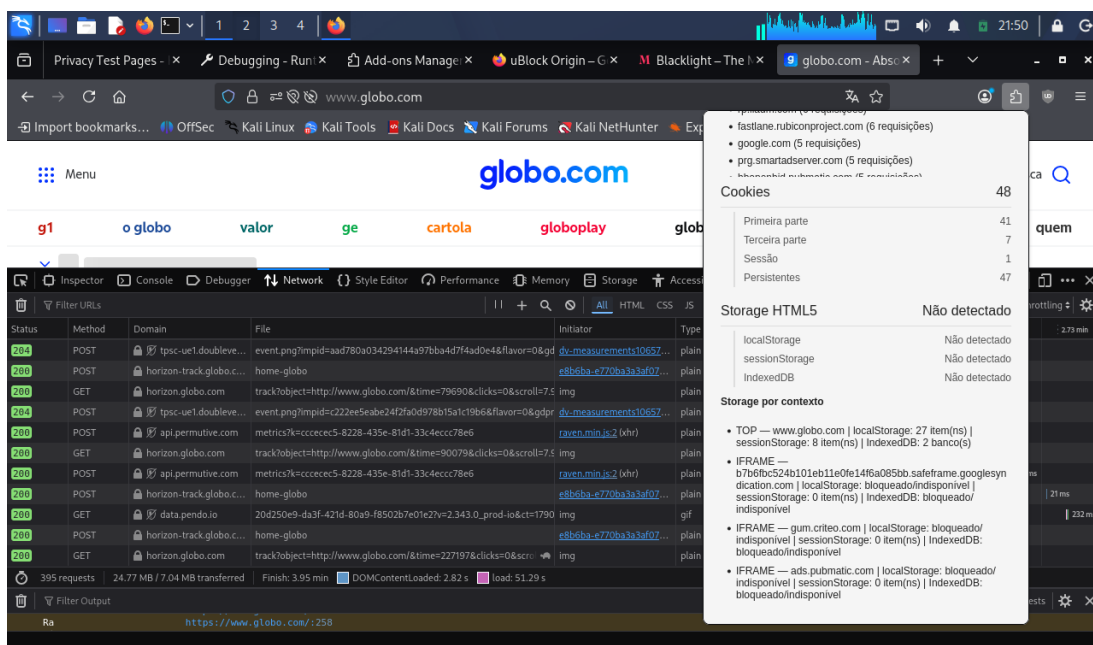


Figura 20 — globo: 48 cookies (41/7; 1/47) e storage por contexto. (evidencias/sites/site-2/cookie-storage.png)

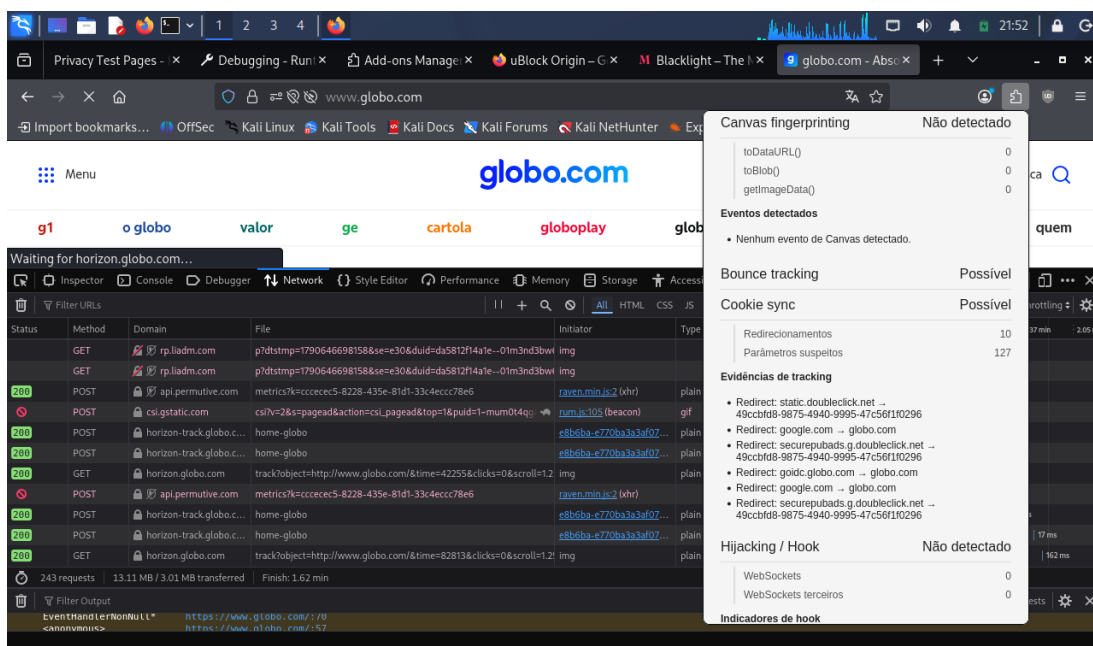


Figura 21 — globo: canvas não detectado; bounce e cookie sync possíveis; nenhum hook. (evidencias/sites/site-2/canvas-cookiesync-hook.png)

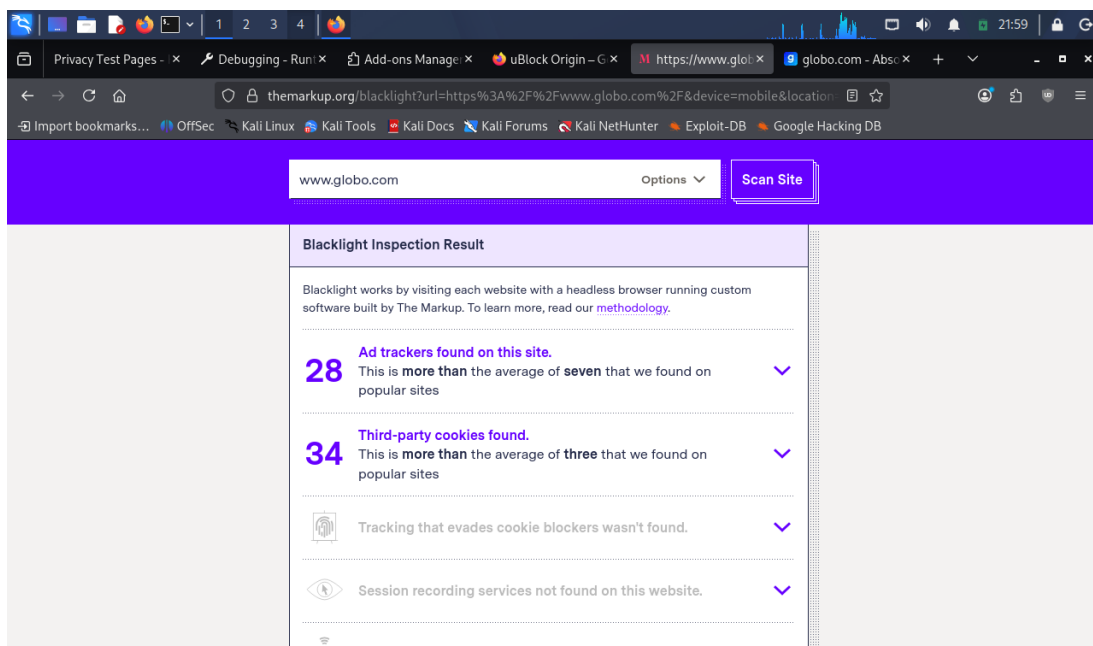


Figura 22 — Blacklight globo: 28 ad trackers, 34 cookies de terceiros. (evidencias/sites/site-2/globo-blacklight.png)

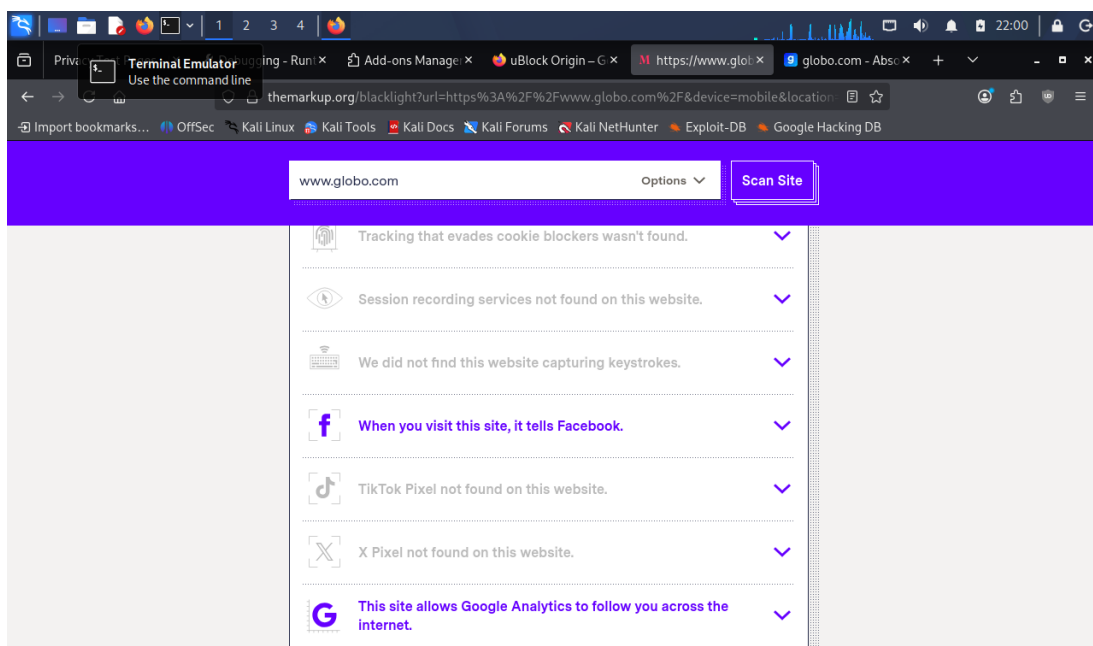


Figura 23 — Blacklight globo: Facebook e Google Analytics; TikTok e X não. (evidencias/sites/site-2/globo-blacklight-2.png)

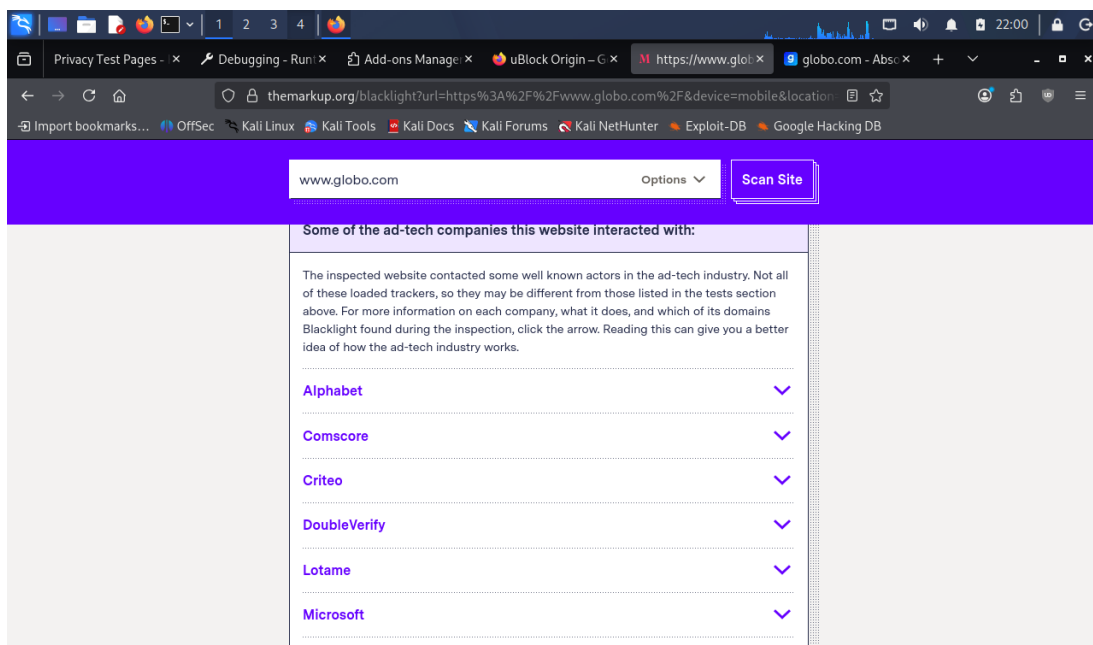


Figura 24 — Blacklight globo: empresas de ad-tech (1/2). (evidencias/sites/site-2/globo-blacklight-3.png)

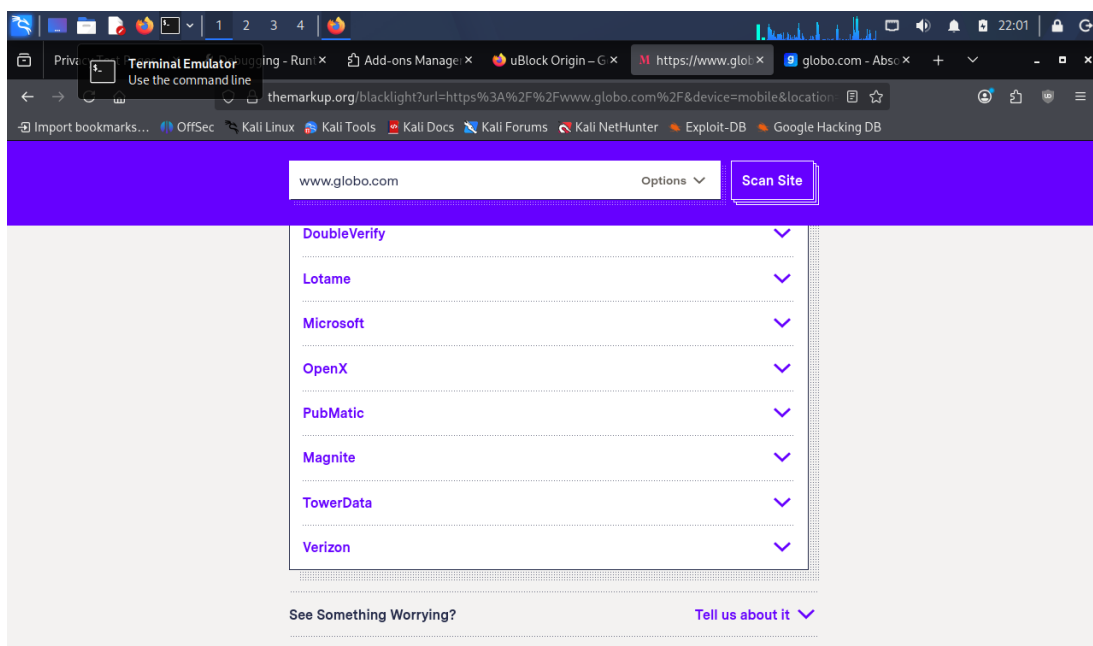


Figura 25 — Blacklight globo: empresas de ad-tech (2/2). (evidencias/sites/site-2/globo-blacklight-4.png)

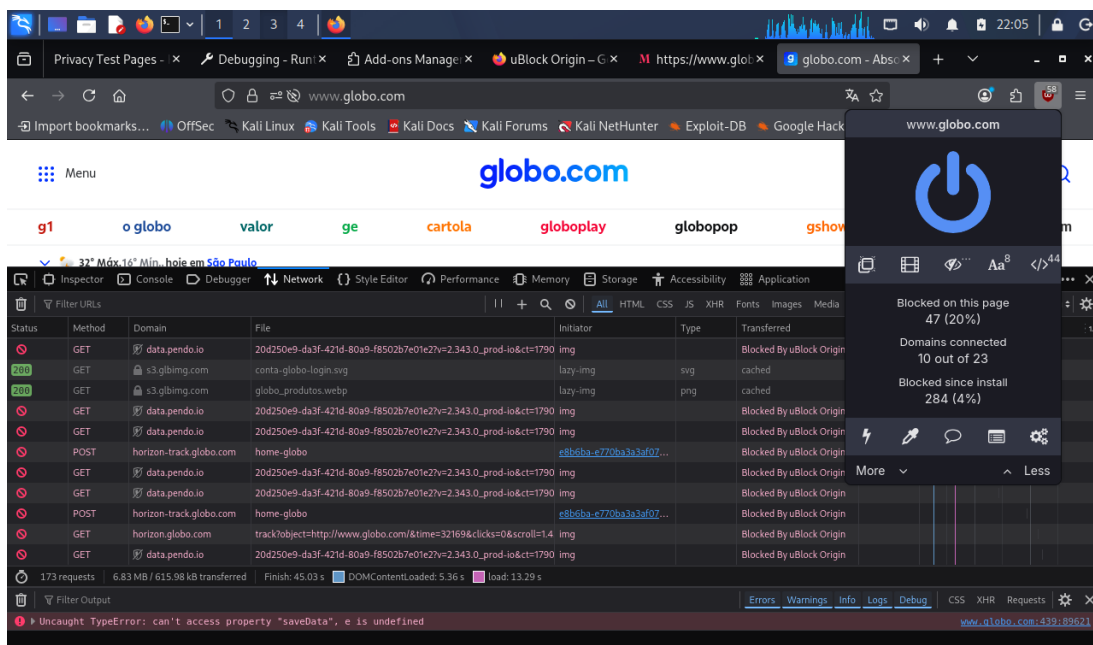


Figura 26 — uBlock globo: 47 bloqueios (20%), 10 de 23 domínios. (evidencias/sites/site-2/ublock-globo.png)

3.3 mercadolive.com.br (site-3)

Métrica	Plugin	HAR	Blacklight	uBlock Origin
Terceiros	9 hostnames	7 hostnames / 5 domínios registráveis (mlstatic, mercadolibre, mercadoclics, google, hotjar)	11 ad trackers	16 bloqueios (4%); 8 de 10 domínios
Cookies de 3ª parte	0 (10 de 1ª)	9 Set-Cookie _d2id de mercadoclics.com	16	-
Sessão / persistentes	1 / 9	-	-	-
Storage HTML5	TOP: sessionStorage 1; iframe accounts.google.com vazio	-	-	-
Canvas	Não detectado	-	Não encontrado	-
Cookie sync	Possível (melidata.mercadolivre.com <-> melidata.mercadolivre.com / mercadopago)	-	-	-
Bounce	Possível (mercadolive.com.br -> click1.mercadolivre.com.br -> mercadolive.com.br)	único 3xx: mercadolive.com.br -> www.mercadolivre.com.br	-	-
Hook (WebSocket)	0	0	-	-
Pixels	static.hotjar.com, script.hotjar.com	hotjar-720738.js; nenhuma requisição para facebook/tiktok/twitter	Facebook: sim; TikTok: sim; X: sim; GA remarketing: não	-
Score	60 / 100	-	sem score numérico	-

Reconciliação.

- **Facebook, TikTok e X: Blacklight detecta, plugin e uBlock não.** O HAR não tem nenhuma requisição para facebook, tiktok ou twitter/x. Os pixels não foram carregados na nossa sessão, então nenhuma extensão poderia vê-los. O Blacklight visitou uma URL diferente (www.mercadolivre.com.br/?skipInApp=true&mat_..., parâmetros de campanha visíveis no print) e com perfil mobile: é o tráfego de campanha paga que carrega os pixels de conversão das redes sociais.
- **Cookies de 3ª parte (0 x 16), com evidência no HAR.** O navegador *tem* um cookie de terceira parte de mercadoclics.com, mas o plugin mostra 0. No HAR, as 4 primeiras requisições para print1.mercadoclics.com/display/prints/MLB/count (Sec-Fetch-Dest: image, modo no-cors) enviam o cabeçalho *Cookie: _d2id=282a67d5-...*, ou seja, o cookie existe no navegador. As 9 requisições seguintes são fetch em modo CORS (Sec-Fetch-Mode: cors) e não enviam cabeçalho Cookie; por isso o servidor responde com um Set-Cookie _d2id novo a cada vez (087eff23-..., 34c7c9bb-..., 0047bff0-...). O plugin não enxerga esse cookie por duas causas: (1) cookies de terceiros ficam particionados pelo site de topo (Total Cookie Protection) e cookies.getAll() sem *partitionKey* não os devolve; (2) o plugin consulta cookies.getAll({domain: "print1.mercadoclics.com"}), que não inclui cookies do domínio pai .mercadoclics.com. O Blacklight, sem particionamento e com os pixels sociais carregados, conta 16.
- **mercadoclics: concordam.** print1.mercadoclics.com/count?d=... (13 requisições no plugin) é exatamente o que o uBlock bloqueia no print do uBlock (fetch iniciado por bases.min.js).
- **Hotjar: plugin vê, Blacklight diz "session recording not found".** O HAR tem static.hotjar.com/c/hotjar-720738.js. O script carregou, mas a gravação depende de amostragem configurada no Hotjar; o Blacklight só marca quando há envio de eventos de gravação. O plugin lista o domínio mas não classifica o serviço.

- **Bounce: falso positivo do plugin.** click1.mercadolivre.com.br é subdomínio do próprio site. O plugin compara hostnames (só remove "www."), então mercadolibre.com.br e click1.mercadolivre.com.br parecem domínios diferentes e o clique em um banner (redirect de click tracking) forma o padrão A -> B -> A.
- **Indicador de cookie sync: propagação de identificador dentro do mesmo grupo.** O mesmo ID aparece em melidata.mercadolivre.com, melidata.mercadolivre.com, melidata.mercadopago.com e .com.br, todos do Mercado Livre. O que se observa é o mesmo identificador sendo propagado entre domínios da própria empresa (telemetria melidata), e não troca de IDs com uma ad-tech externa; tratamos como falso positivo do indicador de cookie sync. O Blacklight só lista Alphabet como empresa contatada.
- **Terceiros (9 x 11 x 8 de 10).** http2.mlstatic.com (163 req) e api.mercadolivre.com são CDN/API do próprio grupo, contados como terceiros pelo plugin (domínio registrável diferente).

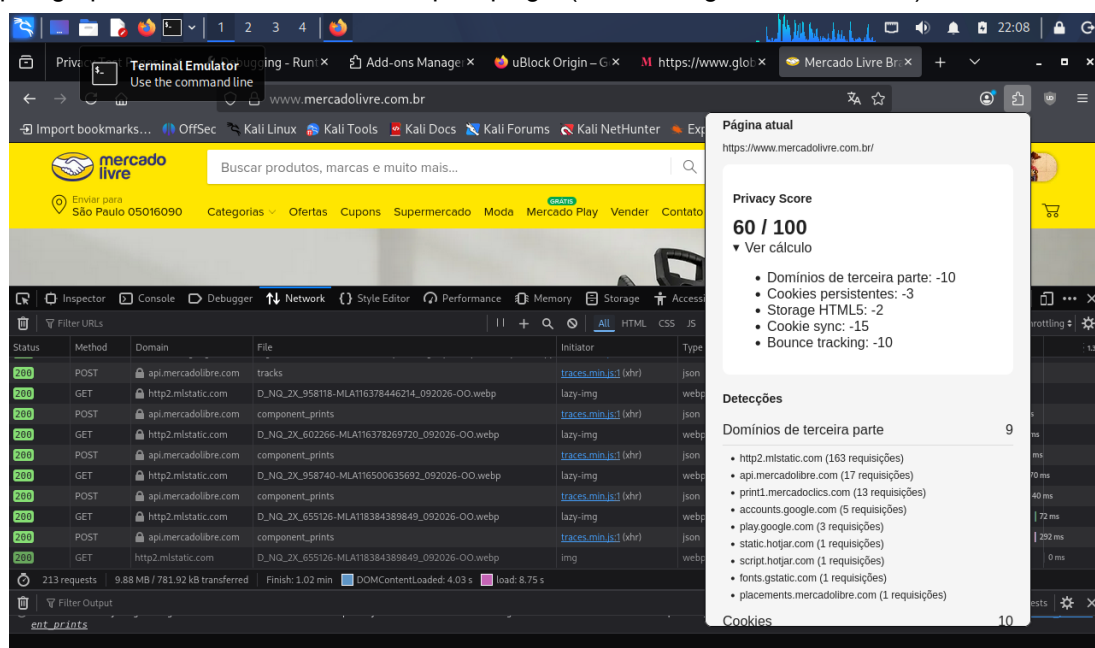


Figura 27 — mercadolibre: score 60 e 9 domínios terceiros. (evidencias/sites/site-3/privacy-score-dominios-3-parte.png)

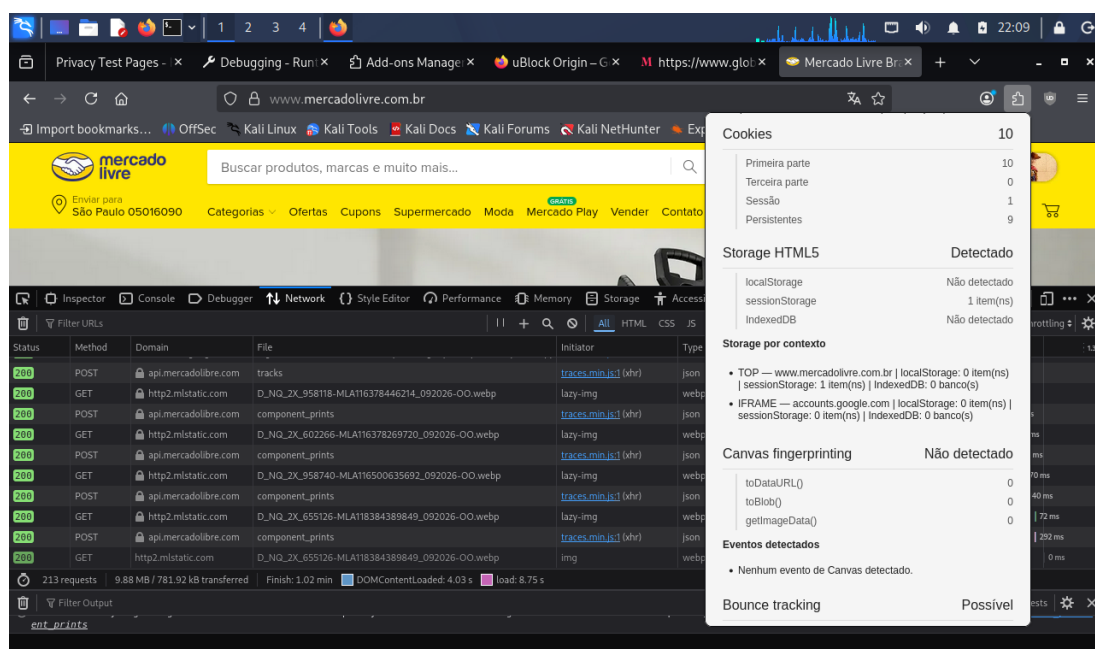


Figura 28 — mercadolibre: 10 cookies, todos de 1ª parte; storage; canvas não detectado. (evidencias/sites/site-3/cookie-storage-canvas.png)

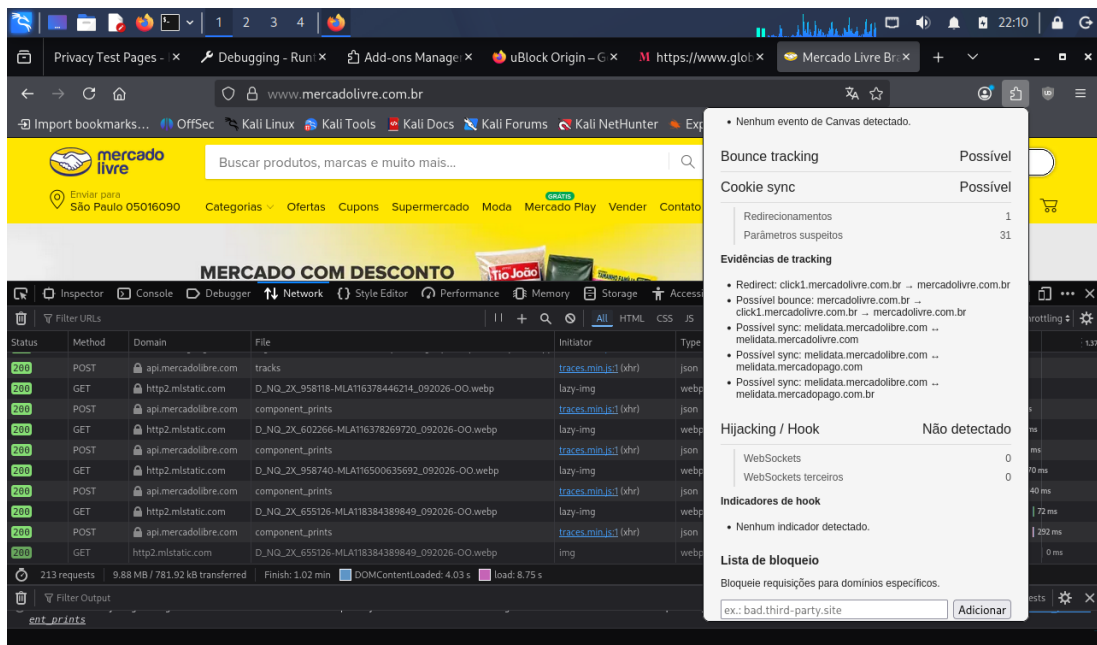


Figura 29 — mercadolive: bounce via click1.mercadolivre.com.br e sync entre domínios melidata. (evidencias/sites/site-3/cookiesync-hook.png)

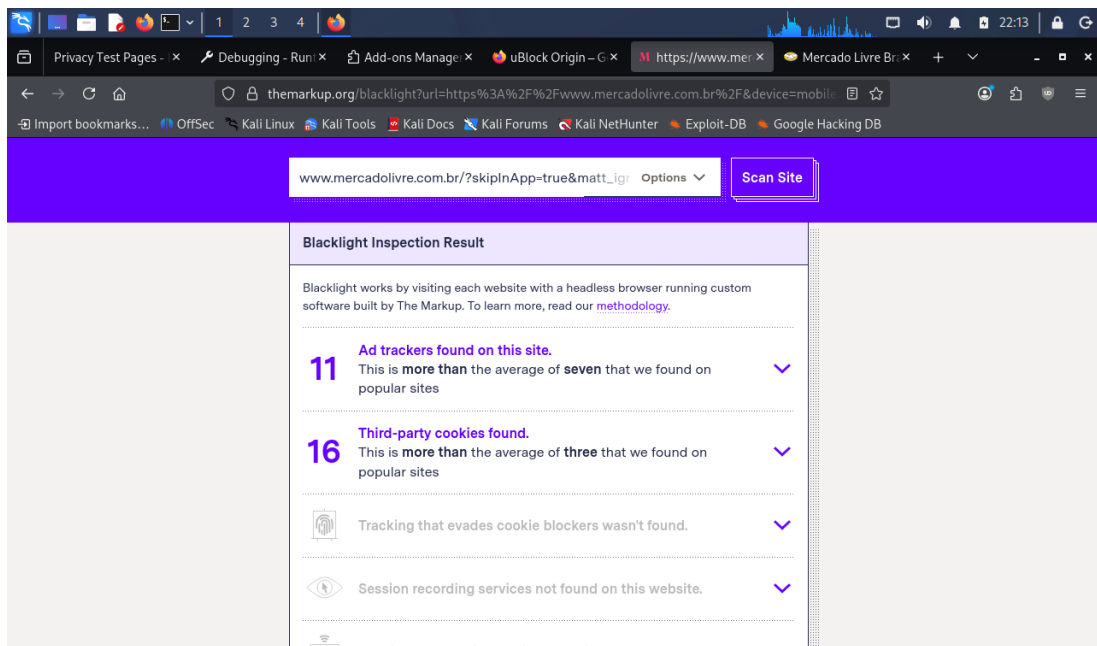


Figura 30 — Blacklight mercadolive: 11 ad trackers, 16 cookies de terceiros. (evidencias/sites/site-3/mercadolivre-blacklight.png)

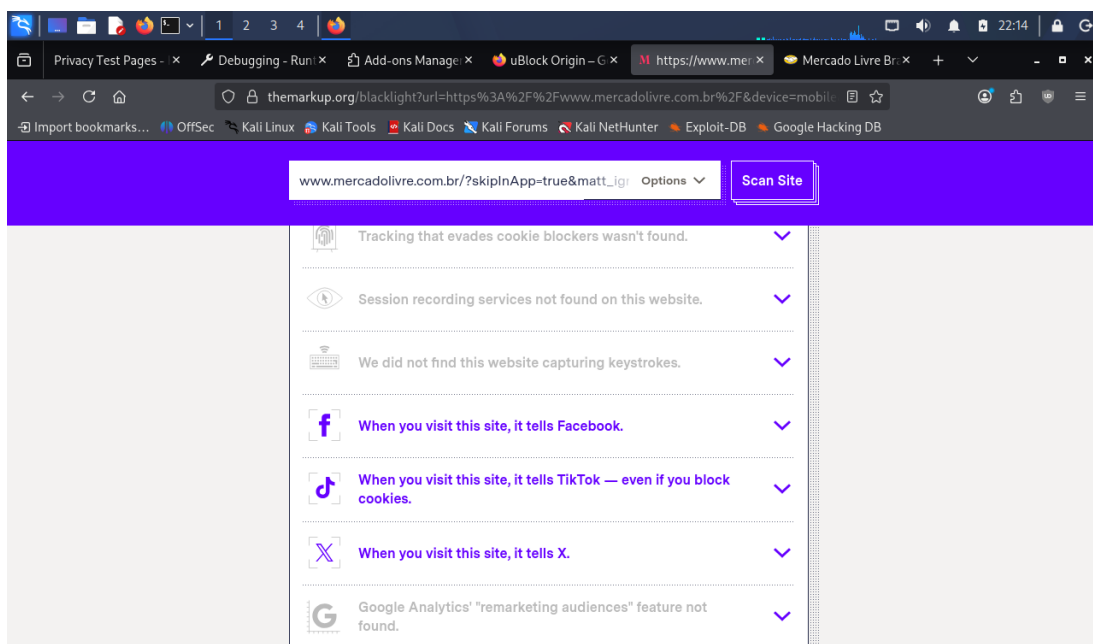


Figura 31 — Blacklight mercadolive: Facebook, TikTok e X. (evidencias/sites/site-3/mercadolivre-blacklight-2.png)

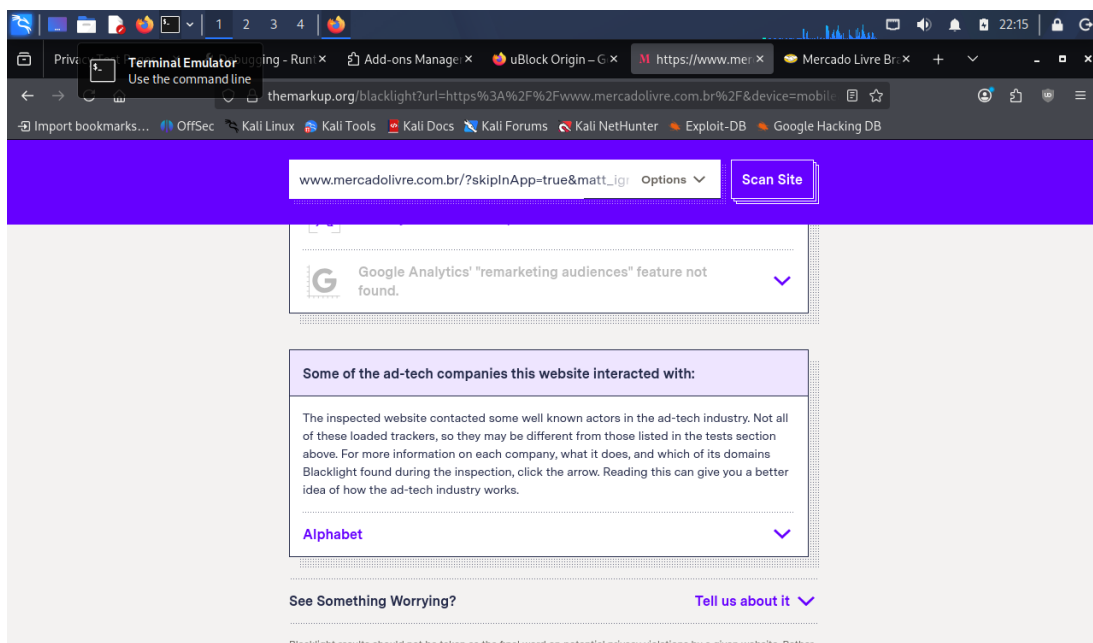


Figura 32 — Blacklight mercadolive: Alphabet como única empresa listada. (evidencias/sites/site-3/mercadolivre-blacklight-3.png)

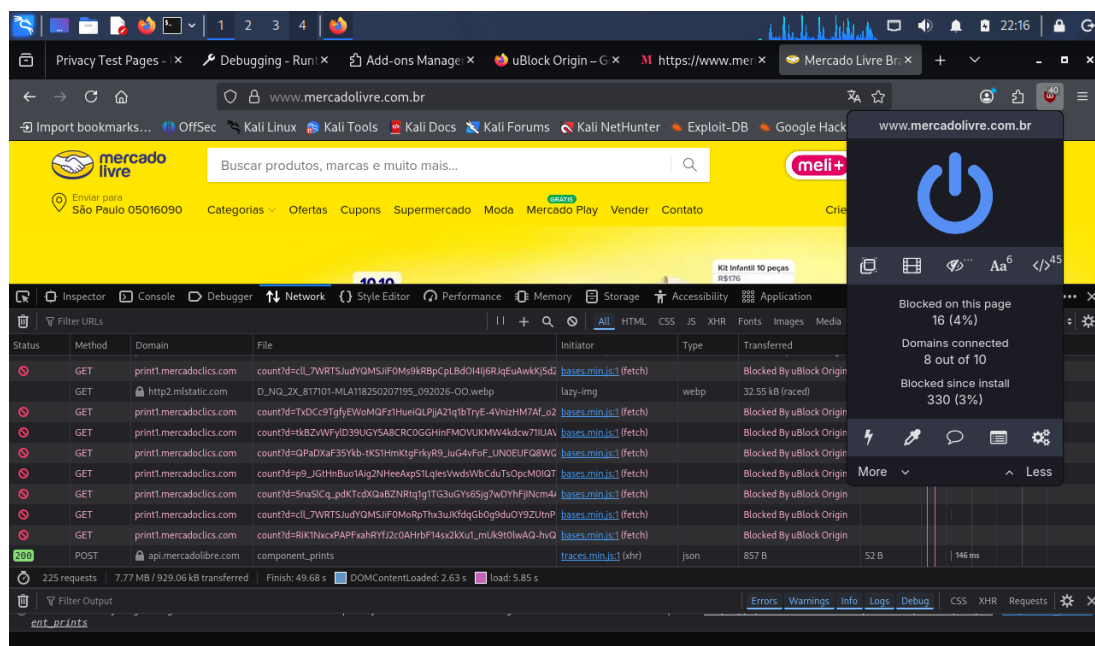


Figura 33 — uBlock mercadolive: 16 bloqueios (4%), print1.mercadoclics.com bloqueado.
(evidencias/sites/site-3/ublock-mercadolivre.png)

4. Pontuação de privacidade

4.1 Metodologia

O score é **experimental** e deve ser lido como indicador comparativo entre páginas analisadas no mesmo ambiente, não como medida absoluta de privacidade. Os critérios binários (canvas, cookie sync, bounce, hook) dependem de heurísticas sujeitas a falsos positivos: uma única detecção indevida muda o score em 10 a 15 pontos (ver seção 4.3).

A página começa com 100 pontos e perde pontos por critério. As penalidades máximas somam exatamente 100, então o score fica entre 0 (pior) e 100 (melhor). O cálculo é feito no popup (função `calculatePrivacyScore` em `popup/popup.js`) e o detalhamento aparece em "Ver cálculo".

Critério	Faixas / regra	Máx.	Justificativa
Domínios de terceira parte	1-5: -5; 6-10: -10; 11-20: -15; >=21: -20	20	Cada terceiro recebe IP, User-Agent e Referer; é a base de todos os outros rastreamentos. Faixas porque sites grandes usam dezenas de CDNs e a diferença entre 40 e 70 importa menos que entre 0 e 5.
Cookies de 3ª parte	1-2: -5; 3-5: -10; >=6: -15	15	Identificador que reconhece o usuário entre sites diferentes (rastreamento cross-site clássico).
Cookies persistentes	1-10: -3; 11-30: -6; >=31: -10	10	Mantém identificadores entre sessões; peso menor porque muitos são funcionais (login, carrinho, preferências).
Storage HTML5 (frame principal)	localStorage -4; IndexedDB -4; sessionStorage -2	10	Armazenamento que escapa dos controles de cookie; sessionStorage pesa menos porque some ao fechar a aba.
Indicador de canvas fingerprinting	chamada a <code>toDataURL</code> , <code>toBlob</code> ou <code>getImageData</code> : -15	15	A técnica identifica o dispositivo sem guardar nada no cliente e sobrevive à limpeza de cookies. O detector registra chamadas às APIs usadas para isso, que também têm usos legítimos.
Indicador de cookie sync	mesmo ID em URLs de domínios diferentes: -15	15	Sincronizar IDs junta perfis de rastreadores diferentes. O indicador não distingue troca entre empresas de propagação dentro do mesmo grupo.
Indicador de bounce tracking	presença: -10	10	Contorna o bloqueio de cookies de terceiros fazendo o rastreador virar primeira parte por alguns instantes.
WebSocket para terceiro (hook)	presença: -5	5	É só indicador: chats e notificações legítimos também usam WebSocket.

Canvas, cookie sync, bounce e hook são binários porque, quando a técnica é real, uma única ocorrência já basta para identificar ou ligar o usuário. O custo dessa escolha é que um falso positivo também pesa inteiro.

4.2 Resultado nos 3 sites

Critério	youcom	globo	mercadolivre
Domínios de terceira parte	43 -> -20	75 -> -20	9 -> -10
Cookies de 3ª parte	6 -> -15	7 -> -15	0 -> 0
Cookies persistentes	48 -> -10	47 -> -10	9 -> -3
Storage HTML5	local + IDB -> -8	local + session + IDB -> -10	session -> -2
Indicador de canvas	não -> 0	não -> 0	não -> 0
Indicador de cookie sync	sim -> -15	sim -> -15	sim -> -15 (mesmo grupo)
Indicador de bounce	não -> 0	sim -> -10 (falso positivo)	sim -> -10 (falso positivo)
Hook	não -> 0	não -> 0	não -> 0
Score	32	20	60

4.3 Comparação crítica com o Blacklight

O Blacklight não produz um score numérico; ele reporta contagens (ad trackers, cookies de terceiros) e testes binários. Para comparar, ordenamos os sites pelas contagens do Blacklight e pelo score do plugin.

	youcom	globo	mercadolivre
Blacklight: ad trackers	13	28	11
Blacklight: cookies de 3ª parte	9	34	16
Blacklight: testes positivos	TikTok, GA	Facebook, GA	Facebook, TikTok, X
Plugin: score	32	20	60
Plugin: score sem falsos positivos*	32	30	85

* Removendo o bounce da globo (seção 3.2) e o bounce e o cookie sync entre domínios do próprio grupo no Mercado Livre (seção 3.3).

Onde concordam.

- **Globo nos extremos das duas ferramentas.** Entre os três sites, a globo.com teve ao mesmo tempo o maior número de ad trackers (28) e de cookies de terceiros (34) no Blacklight e o menor score no plugin (20), puxado pelos 75 hostnames terceiros, 7 cookies de terceiros e 47 persistentes e pelo indicador de cookie sync nos leilões de prebid (criteo, LiveRamp).
- **Canvas fingerprinting:** nenhum indicador em nenhum dos três sites, nem pelo Blacklight ("tracking that evades cookie blockers wasn't found") nem pelo plugin (0 chamadas de toDataURL/toBlob/getImageData).
- **Presença de Google Analytics e Facebook na globo** e de TikTok na youcom aparece nas duas ferramentas e nos HARs.

Onde divergem e por quê.

- **Mercado Livre é muito melhor no plugin (60) do que no Blacklight,** onde tem mais cookies de terceiros (16) que a youcom (9) e três pixels sociais. Na nossa sessão os pixels não carregaram (HAR sem facebook/tiktok/twitter) e o cookie _d2id de mercadoclics, que o HAR mostra sendo enviado pelo navegador, não foi lido pelo plugin (particionamento). Com os cookies corretamente contados ($\geq 6 \rightarrow -15$), o score cairia de 60 para 45. Ou seja, parte da diferença é do plugin (particionamento) e parte é do tráfego diferente visitado pelo Blacklight.
- **Falsos positivos do plugin reduzem o score de forma indevida.** A comparação por hostname faz click1.mercadolivre.com.br e o fluxo de chegada pelo Google parecerem bounce (-10 cada) e o sync entre domínios melidata do mesmo grupo vale -15. Sem eles, Mercado Livre iria a 85, bem longe da youcom e da globo, o que mostra que o score tem os critérios binários (bounce, sync) com peso alto demais em relação à qualidade da heurística.
- **O plugin mede coisas que o Blacklight não mede:** indicador de cookie sync e storage HTML5 penalizam os três sites, mas não existem no Blacklight. Por outro lado, o Blacklight testa session recording e keylogging, que o plugin não tem. Os dois discordaram sobre Clarity (youcom) e Hotjar (Mercado Livre): os scripts estão nos HARs, mas o Blacklight só marca quando a gravação é enviada.
- **Contagem de terceiros satura.** youcom (43) e globo (75) recebem os mesmos -20, embora o Blacklight veja o dobro de ad trackers na globo. Como o plugin não usa lista de rastreadores, CDNs próprias (glbimg.com, mlstatic.com) pesam o mesmo que ad trackers.

Conclusão. Entre os três sites analisados, a Globo apresentou ao mesmo tempo a maior quantidade de ad trackers e de cookies de terceiros no Blacklight e o menor score calculado pelo plugin; as duas ferramentas também concordam na ausência de indicadores de canvas fingerprinting. Como as duas ferramentas não medem as mesmas coisas, isso não define um ranking universal de privacidade. As maiores divergências vêm de (1) cookies de terceiros particionados que o plugin não lê, (2) comparação por hostname em vez de domínio registrável, que gera falsos positivos de bounce e de cookie sync dentro do mesmo grupo empresarial, e (3) ambiente de visita diferente (headless nos EUA, URL com parâmetros de campanha). Os ajustes mais efetivos: ler cookies com partitionKey, comparar por eTLD+1 e usar uma lista de rastreadores (ex.: Tracker Radar).